

# Reporte Ejecutivo de Gestión de Riesgos

Responsable de Seguridad de la Información: Lautaro Fiochetta  
Dirigido: Directorio de la Clínica

## Resumen ejecutivo

En consecuencia de la auditoría externa reciente, que identificó debilidades en la gestión de riesgos de la institución, se realizó un relevamiento inicial utilizando SimpleRisk como herramienta de registro. Se identificaron y documentaron 9 riesgos específicos al contexto de la clínica (120 empleados, 800 pacientes/día, historias clínicas digitales, datos de obras sociales y facturación), evaluados según probabilidad e impacto. Los actores externos que amenazan a la institución buscan explotar principalmente el exceso de confianza, los controles insuficientes y la falta de verificación de accesos. Este informe resume los hallazgos principales y las acciones prioritarias recomendadas.

## Top 5 riesgos por nivel

1. Acceso no autorizado a historia clínica — Confidencialidad — Muy alto
2. Phishing a personal administrativo — Operativo — Muy alto
3. Disponibilidad de datos: caída temporal del sistema — Disponibilidad — Alto
4. Filtración de datos de pagos — Confidencialidad — Alto
5. Integridad de datos en historia clínica — Integridad — Alto

## Estado de los planes de acción

- RBAC + logging de accesos (Riesgo 1) — Responsable: Jefe de Sistemas — Vencimiento: 30/11/2026 — Presupuesto: USD 3.500 — Estado: No iniciado
- Concientización + MFA (Riesgo 8) — Responsable: RRHH + Jefe de Sistemas — Vencimiento: 31/10/2026 — Presupuesto: USD 1.200 — Estado: No iniciado
- Generador de respaldo (Riesgo 4) — Responsable: Jefe de Sistemas — Vencimiento: 15/12/2026 — Presupuesto: USD 8.000 — Estado: No iniciado

Ningún control aislado alcanza por sí solo: el plan de tratamiento combina controles técnicos (RBAC, MFA, cifrado), organizativos (capacitación, políticas de revisión) y físicos (generador, cifrado de dispositivos), de modo que si una capa falla, la siguiente contiene el impacto.

## Recomendaciones prioritarias

1. Priorizar la ejecución de los 3 planes de acción dentro de los próximos 90 días, empezando por el de menor esfuerzo y mayor impacto (concientización + MFA).
2. Formalizar un proceso de baja de accesos vinculado a RRHH.
3. Definir una política de retención y destrucción segura de información, alineada a la Ley 25.326.
4. Evaluar la contratación de un seguro de ciberseguridad para transferir parte del riesgo residual.